

Inlämningsuppgift-infosäkerhet

Jonas Björk

Inlämningsuppgift

Kurs: Informationssäkerhet och IT-juridik

- Uppgiften ska göras individuellt, allt arbete ska vara ditt eget.
- Omfattningen ska vara runt 10-13 sidor (exklusive framsida, innehållsförteckning och eventuella bilagor), med normal formatering (12pt, 1.5 radavstånd).
- Alla påståenden ska vara underbyggda med hänvisningar till standarder eller andra trovärdiga källor.
- Använd ett sakligt och professionellt språk som passar en konsultrapport.
- Lämna in ditt arbete i PDF-format.

Scenario

NordTech Solutions AB - är ett medelstort IT-konsultbolag med 120 anställda, baserat i Helsingborg. Företaget erbjuder molntjänster, systemutveckling och driftlösningar till kunder inom hälso- och sjukvård, kommunal verksamhet och detaljhandel.

NordTech har nyligen genomgått en snabb tillväxtfas och insett att deras informationssäkerhetsarbete inte hängt med. De saknar ett formellt ledningssystem för informationssäkerhet (LIS) och har fått påpekanden från en av sina större kunder inom sjukvårdssektorn om att de behöver förbättra sitt systematiska säkerhetsarbete.

Företaget hanterar bland annat:

- Personuppgifter för sina anställda och sina kunders slutanvändare
- Betalkortsuppgifter åt en detaljhandelskund
- Drifttjänster som klassas som samhällsviktiga för en kommunal kund

Uppgiftsbeskrivning

Vi tänker oss att vi har fått uppdraget att arbeta som informationssäkerhetskonsult åt NordTech Solutions AB. Uppgiften består av tre delar som hänger ihop och tillsammans ger en helhetsbild av organisationens

informationssäkerhetsutmaningar.

Del 1 - Nulägesanalys och centrala begrepp (ca 3-4 sidor)

Beskriv NordTechs nuvarande situation utifrån centrala begrepp inom informationssäkerhet. Analysen ska innehålla:

- En beskrivning av de övergripande hot, sårbarheter och risker som NordTech kan stå inför givet deras verksamhet och kundkrets. Ge konkreta exempel som är relevanta för organisationen.
- En förklaring av varför ett ledningssystem för informationssäkerhet (LIS) behövs och vad det består av. Beskriv nyttan med ett systematiskt informationssäkerhetsarbete för just NordTech.
- En reflektion över vilka utmaningar som finns i skyddandet av personlig integritet i relation till informationssäkerhet, specifikt kopplat till de typer av data NordTech hanterar.

Del 2 - Regelverksanalys (ca 4-5 sidor)

NordTech berörs av flera lagar, standarder och regelverk. Redogör för följande och koppla dem till NordTechs verksamhet:

- **ISO 27001/27002** - Hur kan dessa standarder hjälpa NordTech att bygga upp sitt informationssäkerhetsarbete? Beskriv de viktigaste delarna och hur de relaterar till att skapa ett LIS.
- **GDPR** - Vilka krav ställer GDPR på NordTech givet att de hanterar personuppgifter åt både sig själva och sina kunder? Ge konkreta exempel på åtgärder som krävs.
- **PCI DSS** - NordTech hanterar betalkortsuppgifter åt en detaljhandelskund. Beskriv vad PCI DSS innebär och vilka krav som är mest relevanta i deras situation.
- **NIS2** - NordTech levererar drifttjänster till en kommun. Förklara hur NIS2-direktivet påverkar dem och vilka skyldigheter det medför.
- **CER-direktivet** - Beskriv kort vad CER innebär och hur det förhåller sig till NIS2 i NordTechs kontext.
- **Säkerhetsskydd** - Förklara grunderna i säkerhetsskydd och diskutera om det kan vara relevant för NordTech.

Diskutera också hur etik, lagar och företagspolicy samverkar och påverkar informationssäkerheten i en organisation som NordTech.

Del 3 - Gap-analys och riskanalysplan (ca 3-4 sidor)

Genomför en förenklad gap-analys och ta fram en plan för riskanalys.

Välj minst tre områden från ISO 27001 (Annex A) och bedöm var NordTech sannolikt har brister (gap) i relation till gällande lagar och regler. Motivera valen och beskriv vad som saknas. Ta fram en plan för en riskanalys som NordTech kan använda. Planen ska beskriva:

- Vilka tillgångar som ska inventeras
- Hur hot och sårbarheter ska identifieras
- Vilken metod som ska användas för att värdera risker
- Hur risker ska prioriteras och hanteras

Diskutera möjligheter och begränsningar med informationssäkerhet - i vilken utsträckning kan NordTech uppnå säkerhet, och var går gränsen för vad tekniska och organisatoriska åtgärder kan åstadkomma?